Organization: Mathnasium Learning Center (New York) | **Assessment Framework**: NIST SP 800-53 Rev. 5 / FIPS 199 | **Baseline**: Moderate (Student PII) | **Version**: 1.1 (Final) | **Analyst**: K. Oriol / koriol.github.io

Risk ID	Control ID	Control Class	Control Function	Vulnerability	Threat	Business Impact Category	Security Impact Category (CIA)	Consequence	Inherent Likelihood	Inherent Impact	Inherent Risk Score	Inherent Rating	Recommended Action	Risk Treatment Strategy	Mitigation Action Plan	Residual Likelihood	Residual Impact	Residual Risk Score	Residual Rating	Risk Owner	Status
R-01	AC-02	Administrative	Preventive	Stale Account Persistence (Ghost Accounts): Lack of a synchronized notification trigger between local management and Corporate IT, resulting in active administrative credentials for terminated personnel.	Insider Threat (Former Employee/Terminated Staff): A former employee whose relationship with the center may have soured.	Reputational Operational	Confidentiality	Unauthorized access to Student PII (names, grades, contact info) and proprietary Mathnasium curriculum; high risk of data exfiltration by disgruntled former employees.	5	4	20	Critical	Formalize a Role-Based Access Control (RBAC) Matrix. This document should clearly define what a "Tutor," "Lead Instructor," and "Center Director" can see and do in the system.	Mitigate (Remediate)	1. Establish a formal RBAC Matrix to define role-based access criteria and limit account creation to strictly necessary personnel (AC-02_ODP[01]). 2. Implement an Offboarding Policy requiring the Center Director to submit a deactivation ticket to Corporate IT within 24 hours of staff termination (AC-02_ODP[07]). 3. Conduct Monthly Reconciliation: Perform a manual cross-reference audit between the Portal User Export and the Center Personnel Roster to identify and purge inactive accounts (AC-02_ODP[10]).	1	4	4	Low	Corporate IT	Open
R-02	AC-03	Technical	Preventive	Privilege Escalation Risk: Excessive permissions (Shared sudo access) on primary workstations and a total absence of automated device session locks on mobile endpoints (iPads).	Accidental or Malicious individuals (Staff/Students/Visitors).	Operational Legal / Regulatory	Integrity	Full system compromise; a single unauthorized user (visitor or student) can gain root-level access to the local network, bypass security controls, and modify or delete student records.	4	4	16	High	Implement Automated Access Enforcement and Role-Based Permissions on all local devices.	Mitigate (Remediate)	1. Enforce Least Privilege: Configure unique local user profiles for staff members, removing sudo (Admin) rights from the general "Tutor" login to prevent unauthorized system changes (AC-03_ODP[01]). 2. Enable Mandatory Session Locks: Deploy a 15-minute inactivity timer (Auto-Lock) across all center iPads and laptops to prevent unauthorized access to authenticated sessions (AC-03_ODP[02]). 3. Credential Decoupling: Immediately change the administrative sudo password to a unique key that is not shared with the Guest Wi-Fi password.	1	4	4	Low	Center Director	Open
R-03	AC-07	Technical	Preventive	Hardware-level vulnerability: Local iPads/Tablets lack unsuccessful logon thresholds, creating a "weak link" in the device-to-cloud security chain.	Malicious actors or unauthorized students attempting to gain access via "brute force" or repetitive guessing.	Operational Legal / Regulatory	Integrity	While the Portal is protected, a lost or stolen iPad can be subjected to unlimited local brute-force attempts, potentially exposing cached data or saved browser credentials.	4	3	12	Moderate	Align local hardware security with centralized application standards.	Mitigate (Remediate)	1. Enable local device lockouts on all iPads/tablets to trigger a device wipe or 1-hour lockout after 10 failed attempts (AC-07_ODP[01]). 2. Document the "Device-to-Portal" security standard to ensure all future hardware purchases meet this threshold (AC-07_ODP[02]).	1	3	3	Low	Center Director	Open
R-04	AC-18	Technical	Preventive	Credential Convergence & Lack of Segmentation: The public-facing Guest Wi-Fi password is identical to the administrative sudo password. Furthermore, the network lacks a dedicated "Internal" vs. "Guest" Virtual LAN (VLAN) barrier.	External Actors & Unauthorized Guests: Individuals within physical range of the wireless signal (parking lot/lobby) attempting to pivot from the guest network to the internal environment.	Operational Legal / Regulatory	Confidentiality	Lateral Movement & Network Interception: A malicious actor on the Guest Wi-Fi can move laterally to the administrative workstation, intercept student PII traffic, or deploy ransomware across all connected tablets and computers.	4	4	16	High	Implement Secure Wireless Architecture & Network Segmentation.	Mitigate (Remediate)	1. Establish Network Segmentation: Configure separate SSIDs (Internal, Guest, and IoT/CCTV) to isolate public traffic from administrative data (AC-18[1]). 2. Enforce Password Uniqueness: Rotate the Internal Wi-Fi and administrative sudo passwords to ensure they are distinct and complex (AC-18[4]). 3. Physical Security of Credentials: Remove the "Sticker Password" from public view and implement a digital or hidden method for authorized guest access (AC-18[2]).	1	4	4	Low	Center Director	Open
R-05	AT-02	Administrative	Preventive	Lack of Contextual Security Awareness: Training is limited to generic corporate modules and fails to address local-specific threats like the "Unlocked MDF Closet" or "Physical Password Exposure."	Social engineering, insider negligence, or accidental data disclosure by staff.	Reputational Operational Legal / Regulatory	Confidentiality	Social Engineering & Negligence: Staff may inadvertently allow unauthorized "technicians" into the server closet or mishandle PII because they have not been trained to recognize the center's unique physical and local attack vectors.	4	4	16	High	Develop and Implement a Center-Specific Security Training Supplement.	Mitigate (Remediate)	1. Develop a "Local Security SOP": Create a brief training addendum that covers physical security protocols for the PE-03 closet and secure tablet storage (AT-02.b). 2. Enforce Refresher Frequency: Mandate a security awareness refresher every 12 months for all staff to ensure long-term retention of protocols (AT-02_ODP[01]). 3. Update Training Curriculum: Review and update local training content annually to incorporate "Lessons Learned" from recent incidents or new urban threat profiles (AT-02_ODP[06]).	2	4	8	Low	Center Director	Open
R-06	AT-03	Administrative	Preventive	Absence of Role-Specific Training: The organization relies on a "one-size-fits-all" training model that does not define the unique security responsibilities of administrative vs. instructional roles.	Administrative Errors & Insider Negligence: Key personnel (Center Director/Lead Instructor) failing to execute security-critical duties due to a lack of specialized procedural knowledge.	Operational Legal / Regulatory	Integrity	Governance Failure: Critical security tasks—such as hardware sanitization (RA-05) or account deactivation (AC-02)—are neglected because specific roles have not been formally trained on their execution.	3	4	12	Moderate	Define and Deliver Role-Based Security Training Requirements.	Mitigate (Remediate)	1. Identify Specialized Roles: Formally define roles with "Privileged Access" (Director) and "Standard Access" (Tutors) to tailor training requirements (AT-03[1]). 2. Deploy Specialized Modules: Provide the Center Director with targeted training on "Privileged Account Management" and "Physical Infrastructure Oversight" for the PE-03 closet (AT-03[3]). 3. Establish Retraining Triggers: Mandate specialized training whenever a staff member is promoted to a role with increased system privileges (AT-03_ODP[01]).	1	4	4	Low	Center Director	Open
R-07	AU-06	Technical	Detective	Absence of Log Review / Analysis: System audit records (Portal logs, iPad access logs) are generated but never reviewed, analyzed, or reported at the local level.	Persistent Malicious Actors: Hackers or malicious insiders who remain on the network for extended periods because no one is monitoring the access logs.	Legal / Regulatory Operational	Confidentiality Integrity	Undetected System Compromise: An attacker could exfiltrate student data for months without detection, leading to increased legal liability and a total failure to satisfy data breach notification requirements.	4	5	20	Critical	Establish a Periodic Audit Log Review Process.	Mitigate (Remediate)	1. Detection (Process): Implement a weekly manual review of administrative logon logs and physical access records to identify "Ghost" activity or unauthorized access (AU-06_ODP[01]). 2. Detection (Automation): Configure the Mathnasium Portal to send automated alerts for anomalous login spikes or after-hours activity (AU-06[1]). 3. Communication (Compensatory): Enable lock-screen banners on all center workstations (Mac/iPad) notifying users that system activity is monitored, acting as a deterrent against internal misuse (AC-08).	2	5	10	Moderate	Center Director	Open
R-08	CA-07	Administrative Technical	Detective	Lack of Local Security Visibility: Absence of a localized monitoring framework to track the operational "health" and security status of center-specific assets (CCTV, MDF, Router).	Stealth Intrusions & Silent Failures: Technical malfunctions or physical tampering (e.g., unplugging a camera) that go unnoticed because no monitoring metrics exist.	Operational Reputational Legal / Regulatory	Availability	Unmonitored Vulnerability Window: A critical security component fails silently, creating an "Open Door" for days or weeks without management's knowledge, leading to a total loss of detective capability.	4	3	12	Moderate	Establish a Localized Security Dashboard and Monitoring Plan.	Mitigate (Remediate)	1. Define Security Metrics: Identify key local metrics to be monitored, including CCTV DVR uptime, Firewall connectivity status, and MDF "Unlocked" alerts (CA-07.a). 2. Automate Status Alerts: Where possible, configure the local network gateway to send a "Heartbeat" alert if the primary security camera system goes offline (CA-07.b). 3. Review Security Posture: Establish a weekly "Security Status Report" for the Center Director to confirm all local defenses are active and patched (CA-07_ODP[01]).	1	3	3	Low	Center Director	Open
R-09	CM-02	Technical Administrative	Preventive	Lack of a documented "Standard Operating Environment" (SOE) or baseline configuration for center hardware.	Operational negligence or unauthorized changes by staff/students.	Legal / Regulatory Operational	Integrity	Devices "drift" into an insecure state where previous fixes (like the AC-7 lockouts) are accidentally disabled, re-opening old vulnerabilities.	4	3	12	Moderate	Establish and Enforce a System Baseline Configuration.	Mitigate (Remediate)	1. Develop a "Secure Baseline" checklist for all Chromebooks, iPads, and the MacBook Pro (CM-02a.[02]). 2. Implement "Least Functionality" by disabling all non-essential services, such as Guest Accounts and Unnecessary Apps (CM-07 / CM-02_ODP[01]). 3. Conduct a Quarterly configuration audit to ensure devices still match the baseline (CM-02_ODP[02]).	1	3	3	Low	Center Director	Open
R-10	CM-06	Technical	Preventive	Unhardened Gateway Configuration: Universal Plug and Play (UPnP) is enabled, and the default remote management ports are active on the Verizon Gateway.	External Threat Actors (Botnets/Scanners): Automated scripts that scan the internet for open UPnP ports to gain entry into private networks and deploy malware.	Legal / Regulatory Operational	Confidentiality	Network Perimeter Breach: An attacker can remotely bypass the firewall, intercept all center traffic (including Portal logins), and use the center's internet connection for illegal activities.	4	5	20	Critical	Harden Perimeter Gateway and Disable Insecure Services.	Mitigate (Remediate)	1. Disable Insecure Protocols: Log into the Verizon Gateway and disable UPnP and "Remote Management" features immediately (CM-06[1]). 2. Change Default Credentials: Update the Gateway's administrative password to a unique, complex string (CM-06[2]). 3. Enable Stateful Inspection: Ensure the built-in firewall is set to "High" or "Typical Security" to drop unsolicited inbound traffic (CM-06_ODP[01]).	1	5	5	Low	Center Director	Open
R-11	CP-02	Administrative	Preventive	Absence of a Formalized Recovery Framework: Dependence on "tribal knowledge" rather than documented procedures for maintaining operations during system or facility outages.	Environmental & Infrastructure Disruptions: Natural disasters (floods/storms), regional power outages, or ISP (Internet) failures that sever access to the Mathnasium Portal.	Operational Financial Physical / Safety	Availability	Operational Paralysis: Inability to access student rosters, progress tracking, or parent emergency contact data, leading to lost revenue and potential student safety liabilities.	4	4	16	High	Develop and Formalize a Center-Specific Contingency Plan.	Mitigate (Remediate)	1. Define Recovery Roles: Formally document "Essential Functions" (e.g., student check-out, instruction) and assign primary/alternate recovery leads (CP-02_ODP[01]). 2. Implement Compensatory "Offline" Controls: Maintain a "Physical Emergency Binder" with printed student rosters and parent contact info updated weekly (CP-02_ODP[02]). 3. Establish an RTO: Define a 4-hour "Recovery Time Objective" (RTO) and authorize the use of a cellular hotspot as a failover for critical Portal access (CP-02_ODP[03]).	2	2	4	Low	Center Director	Open
R-12	IA-02	Technical	Preventive	Credential Sharing & Lack of Attribution: Use of shared administrative authenticators (common passwords) for the Verizon Gateway, MacBook, and iPad fleet.	Accountability Failure (Insider/External): Malicious or negligent actors performing system changes that cannot be traced back to a unique individual.	Legal / Regulatory Operational	Integrity Availability	Audit & Forensic Failure: Inability to attribute specific data access or system modifications to an individual user, nullifying the "Non-Repudiation" requirement of the NIST framework.	4	3	12	Moderate	Enforce Unique Identification and Multifactor Authentication (MFA).	Mitigate (Remediate)	1. Assign Unique User IDs: Abolish shared accounts; issue unique login credentials to every staff member for all local device and portal access (IA-02_ODP[01]). 2. Implement MFA for Admin Roles: Require a secondary factor (SMS, App, or Token) for the Center Director's access to the Router and MacBook (IA-02[1]). 3. Establish Authenticator Complexity: Ensure all unique IDs are tied to passwords meeting the complexity requirements defined in IA-05 (IA-02[5]).	1	3	3	Low	Center Director	Open
R-13	IA-05	Technical Administrative	Preventive	Weak Authenticator Hygiene: Physical exposure of passwords (stickers) and an absence of complexity (entropy) or rotation requirements for center-level accounts.	Credential Harvesting & Visual Hacking: Malicious actors or unauthorized guests obtaining passwords through physical observation or automated brute-force attacks.	Legal / Regulatory Operational	Confidentiality	Persistent Unauthorized Access: Compromised passwords remain valid indefinitely, allowing for trivial administrative takeover and long-term, undetected access to Student PII.	5	4	20	Critical	Implement and Enforce an Authenticator Management Policy.	Mitigate (Remediate)	1. Establish Complexity Standards: Enforce a minimum 12-character length with mixed-case and special character requirements for all local hardware (IA-05.c). 2. Mandate Periodic Rotation: Implement a 90-day password refresh cycle to limit the lifespan of potentially compromised credentials (IA-05_ODP[01]). 3. Physical Decontamination: Immediately remove all physical password displays and incorporate "Authenticator Security" into the staff "Clean Desk" policy (IA-05[1]).	2	4	8	Low	Center Director	Open
R-14	IR-06	Administrative	Detective	Absence of a Formalized Incident Reporting Workflow: Lack of local reporting thresholds or a "Suspected Breach" SOP for center-level anomalies.	Undetected Malicious Persistence: Malware or intruders remaining in the network indefinitely because staff cannot distinguish between a "technical glitch" and a "security event."	Operational Legal / Regulatory Reputational	Confidentiality Integrity	Increased Dwell Time: Delayed reporting prevents rapid containment, allowing a localized event (one iPad) to escalate into a full network data breach.	4	3	12	Moderate	Establish a Local Incident Response and Reporting SOP.	Mitigate (Remediate)	1. Define Reporting Thresholds: Formalize criteria for what constitutes a "reportable event" (e.g., unauthorized server closet entry, unrecognized system apps) (IR-06.a). 2. Create a "Local Emergency Contact Tree": Develop a one-page "Who to Call" sheet for the Center Director, identifying contacts for Corporate IT and local Law Enforcement (IR-06_ODP[02]). 3. Establish Reporting Timelines: Mandate that all suspected security anomalies be reported to the Center Director within 1 hour of discovery (IR-06_ODP[01]).	2	3	6	Low	Center Director	Open
R-15	MA-02	Administrative Technical	Preventive	Unmonitored Maintenance & Sanitization Gaps: Absence of a formal log for third-party technicians and lack of a "Wipe" policy for hardware sent to external repair vendors.	Unauthorized Data Access: Third-party technicians or downstream repair vendors accessing cached PII on devices that were not properly sanitized before leaving the premises.	Legal / Regulatory Reputational	Confidentiality	Data Breach via Supply Chain: Local student data is exposed during the repair process, leading to a regulatory breach and an irreparable loss of parental trust in the center's data handling.	4	3	12	Moderate	Establish a Controlled Maintenance and Sanitization Protocol.	Mitigate (Remediate)	1. Establish a Maintenance Log: Document the date, technician name, company, and specific components replaced for every on-site repair (MA-02_ODP[03]). 2. Mandate Media Sanitization: Enforce a "Wipe-Before-Repair" policy, requiring a factory reset or data sanitization for any device leaving the center (MA-02.d). 3. Authorization Protocol: Formally designate the Center Director as the sole authority for approving on-site maintenance or hardware removal (MA-02_ODP[01]).	1	3	3	Low	Center Director	Open

Organization: Mathnasium Learning Center (New York) | **Assessment Framework**: NIST SP 800-53 Rev. 5 / FIPS 199 | **Baseline**: Moderate (Student PII) | **Version**: 1.1 (Final) | **Analyst**: K. Oriol / koriol.github.io

Risk ID	Control ID	Control Class	Control Function	Vulnerability	Threat	Business Impact Category	Security Impact Category (CIA)	Consequence	Inherent Likelihood	Inherent Impact	Inherent Risk Score	Inherent Rating	Recommended Action	Risk Treatment Strategy	Mitigation Action Plan	Residual Likelihood	Residual Impact	Residual Risk Score	Residual Rating	Risk Owner	Status
R-16	MP-06	Physical Administrative	Preventive	Absence of a Formal Media Sanitization Program: Lack of defined procedures for the secure disposal of retired or repurposed assets (The "Retired Hardware Pile").	Data Scavenging & Identity Theft: Unauthorized third parties or "e-waste scavengers" recovering PII from discarded or sold hardware.	Legal / Regulatory Reputational	Confidentiality	Post-Lifecycle Data Spill: Student PII is recovered from un-sanitized devices long after they leave the center, leading to significant regulatory fines and catastrophic brand damage.	4	4	16	High	Formalize a Media Sanitization Policy based on NIST SP 800-88.	Mitigate (Remediate)	1. Implement a Sanitization Log: Track the "Clear" or "Purge" status of every retired device, including serial numbers and the method of destruction used (MP-06_ODP[01]). 2. Enforce NIST 800-88 Standards: Mandate "Purge" level factory resets for iPads and Chromebooks. For non-wipable media (SD cards/USB), mandate physical destruction (MP-06.a / MP-06.b). 3. Obtain Proof of Disposal: For bulk disposal, require a "Certificate of Destruction" from the vendor to provide a legal chain of custody for the sensitive data (MP-06_ODP[04]).	1	4	4	Low	Center Director	Open
R-17	PE-03	Physical	Preventive	Absence of Physical Perimeters: Unlocked MDF (Server) closet and a lack of a formal inventory for physical keys/access cards.	Unauthorized Physical Access: Intruders, unescorted visitors, or former employees with unreturned keys tampering with network infrastructure.	Operational Physical / Safety Legal / Regulatory	Integrity Availability	Network Bypass & Infrastructure Sabotage: Physical tampering with the Gateway or CCTV DVR allows an attacker to bypass digital firewalls, install hardware "sniffers," or disable security monitoring entirely.	4	3	12	Moderate	Establish Physical Access Control Zones and Key Management.	Mitigate (Remediate)	1. Zone Designation: Formally designate the MDF closet as a "Restricted Access Zone" and install a commercial-grade lock or electronic keypad (PE-03_ODP[01]). 2. Implement Visitor Escort Policy: Mandate that all third-party technicians and visitors be escorted by authorized staff when entering technical zones (PE-03.d). 3. Formalize Key Management: Establish a Key Control Log to track all physical keys issued and mandate a "Lock Rotation" protocol whenever a key-holder is terminated (PE-03_ODP[09]).	1	3	3	Low	Center Director	Open
R-18	PE-06	Physical Administrative	Detective	Passive Monitoring Stance: CCTV is recorded but lacks a proactive review program, defined alert triggers, or coverage verification for the restricted MDF zone.	Undetected Physical Intrusion: Malicious actors or unauthorized visitors "casing" the center or propping doors open to gain later entry without immediate detection.	Operational Reputational Physical / Safety	Integrity Availability	Delayed Incident Detection: Security anomalies—such as unauthorized access to the server closet—are missed, allowing physical breaches to go unaddressed until after significant damage or theft has occurred.	4	3	12	Moderate	Implement a Formalized Physical Security Review Cycle.	Mitigate (Remediate)	1. Establish Proactive Spot-Checks: Perform a weekly review of CCTV footage focused specifically on "Restricted Zones" (MDF/Safe) to identify anomalies (PE-06_ODP[01]). 2. Define "Trigger Events": Formalize specific incidents (e.g., MDF door open alerts, after-hours motion) that require immediate footage analysis and incident reporting (PE-06_ODP[02]). 3. Correlate Physical/Digital Logs: Cross-reference physical security logs with the digital login audits (AU-06) to ensure physical presence matches system activity (PE-06.c).	2	3	6	Low	Center Director	Open
R-19	PL-02	Administrative	Preventive	Lack of a Defined Security Authorization Boundary: Absence of a localized System Security Plan (SSP) to document how security controls are implemented at the center level.	Compliance Failure & Strategic Drift: Failure to satisfy regulatory audits due to a lack of documented security architecture and defined asset ownership.	Legal / Regulatory Operational	Integrity	Governance Paralysis: Inability to perform accurate Privacy Risk Assessments or maintain a verified security posture, leading to "shadow IT" and unmanaged hardware risks.	5	3	15	Moderate	Develop and Formalize a Localized System Security Plan (SSP).	Mitigate (Remediate)	1. Define the Authorization Boundary: Create a comprehensive local hardware inventory including all iPads, Chromebooks, and network assets (PL-02.a). 2. Establish Management Oversight: Define specific roles for the Center Director to review and update the local security posture annually (PL-02_ODP[01]). 3. Map Data Flows: Document where student PII is cached locally and coordinate protection strategies with Corporate IT (PL-02.a[5]).	1	3	3	Low	Center Director	Open
R-20	PS-02	Administrative	Preventive	Undefined Position Risk Levels: Personnel roles are not categorized based on their level of access to PII or critical infrastructure, leading to inconsistent background screening.	Insider Threat (Malicious/Negligent): Individuals with high-privilege access (like the Center Director) may not be subjected to the rigorous vetting required for their level of responsibility.	Legal / Regulatory Reputational	Confidentiality	Personnel Security Gaps: Hiring individuals for high-risk positions (handling child PII) without the appropriate "High-Risk" designation and subsequent vetting increases the likelihood of a trusted-insider breach.	3	4	12	Moderate	Assign Risk Designations to All Center Roles.	Mitigate (Remediate)	1. Categorize Local Roles: Assign a "Moderate" or "High" risk designation to the Center Director and "Low" risk to instructional staff based on their system access levels (PS-02[1]). 2. Establish Vetting Requirements: Align background check depth with the risk designation (e.g., enhanced financial/criminal checks for management roles) (PS-02[2]). 3. Review Designations Annually: Ensure position risk levels are updated if staff responsibilities change, such as a Tutor being promoted to a Lead role (PS-02_ODP[01]).	1	4	4	Low	Center Director	Open
R-21	PS-04	Administrative	Preventive	Absence of a Formal Offboarding Workflow: Lack of defined timelines for revoking access and retrieving center assets (keys/tablets) upon staff departure.	Malicious/Negligent Former Employees: Terminated staff retaining access to the Mathnasium Portal or physical premises, leading to data exfiltration or curriculum theft.	Legal / Regulatory Reputational Financial	Confidentiality Integrity	Persistent "Zombie" Access: Dormant accounts remain active indefinitely, creating a massive hole in the center's security perimeter and violating PII protection contracts.	5	3	15	Moderate	Implement a Personnel Termination and Property Retrieval SOP.	Mitigate (Remediate)	1. Establish Notification Timelines: Mandate that Center Management notify Corporate IT within 24 hours of any staff departure to ensure digital accounts are disabled (PS-04_ODP[01]). 2. Implement a Termination Checklist: Create a formal sign-off sheet for revoking local credentials, retrieving physical keys, and removing the user from internal communications (PS-04.d). 3. Reaffirm Legal Obligations: Conduct exit interviews that explicitly remind departing staff of their ongoing non-disclosure agreements regarding student PII and proprietary IP (PS-04.c).	1	3	3	Low	Center Director	Open
R-22	RA-02	Administrative	Preventive	Lack of Information System Categorization: The center has not formally categorized its data or systems (Portal vs. iPads vs. Public Wi-Fi) based on the impact of a loss.	Misallocation of Resources: Spending too much time on low-risk assets while neglecting high-risk systems due to a lack of defined priority.	Legal / Regulatory Operational	Confidentiality Integrity Availability	Inadequate Protection of Sensitive Assets: Without categorization, critical PII-containing systems might be treated with the same security rigor as a public-facing game tablet, leading to under-protected student data.	3	4	12	Moderate	Categorize Information Systems Based on FIPS 199 Standards.	Mitigate (Remediate)	1. Perform Security Categorization: Formally label the Mathnasium Portal and Director's MacBook as "Moderate" (due to PII) and the Guest Wi-Fi as "Low" (RA-02[1]). 2. Document Categorization in the SSP: Ensure the system security plan reflects these categories to justify specific security spending (RA-02[2]). 3. Review Categories Annually: Re-assess system categories every 12 months to ensure that if a "Low" system starts handling PII, it is upgraded to "Moderate" (RA-02_ODP[01]).	1	4	4	Low	Center Director	Open
R-23	RA-03	Administrative	Detective	Lack of a Recurring Risk Strategy: Failure to integrate periodic risk assessments into the formal security planning (SSP) lifecycle.	Environmental Drift & Emerging Vulnerabilities: New attack vectors or hardware aging that go unaddressed because the "Security Picture" is outdated.	Legal / Regulatory Operational	Integrity	False Sense of Security: The center remains compliant "on paper" while the actual security posture degrades, leading to eventual breach and audit failure.	4	3	12	Moderate	Formalize the Risk Assessment Lifecycle.	Mitigate (Remediate)	1. Baseline Integration: Formally integrate the results of this 2026 assessment into the local SSP (RA-03.e). 2. Establish Update Triggers: Mandate an annual Risk Review or an ad-hoc assessment following "Significant Changes," such as center renovations or major ISP equipment swaps (RA-03_ODP[03]). 3. Executive Reporting: Disseminate high-risk findings to the Franchise Owner for budget approval and remediation oversight (RA-03.d).	1	3	3	Low	Center Director	Open
R-24	RA-05	Technical	Detective	Ad-hoc Patching & Monitoring: Lack of a systematic process to identify known vulnerabilities (CVEs) in local hardware (Router, iPads, Mac).	Exploitation of Known Flaws: Attackers using publicly available exploit code to target unpatched software or "End-of-Life" (EOL) hardware.	Operational Legal / Regulatory	Confidentiality Integrity	Automated System Compromise: Unpatched devices are easily compromised by botnets or scripts, leading to lateral movement across the center's network.	4	3	12	Moderate	Implement a Vulnerability Monitoring and Remediation Schedule.	Mitigate (Remediate)	1. Establish a Scanning Schedule: Perform a monthly manual check for firmware updates on the Verizon Gateway and iPad OS (RA-05[1]). 2. Monitor "End-of-Life" Assets: Create a tracking sheet to identify hardware approaching its "End-of-Support" date to ensure timely replacement (RA-05_ODP[01]). 3. Prioritize Critical Patches: Establish a 48-hour "remediation window" for any security updates labeled "Critical" by the manufacturer (RA-05.d).	1	3	3	Low		Open
R-25	SA-09	Administrative	Preventive	Lack of Vendor Oversight: Absence of formal security requirements or "Right to Audit" clauses for local service providers (ISP, hardware repair).	Supply Chain Compromise: Negligent or malicious third-party handling of center assets resulting in a "Chain of Custody" breach.	Legal / Regulatory Reputational	Confidentiality	Unprotected Risk Exposure: The franchise owner remains legally liable for data spills occurring at vendor sites due to a lack of contractual risk transfer.	3	4	12	Moderate	Establish a Vendor Risk Management (VRM) Program.	Mitigate (Remediate)	1. Define Security Requirements: Establish a "Vendor Security Addendum" for all local repair shops, mandating data sanitization and non-disclosure (SA-09.a). 2. Contractual Protections: Incorporate "Right to Audit" and "Data Breach Notification" clauses into local service agreements (SA-09_ODP[01]). 3. Annual Vendor Review: Perform a high-level review of the ISP and Portal provider's security posture and uptime SLAs to ensure alignment with center RTOs (SA-09.c).	2	3	6	Low	Center Director	Open
R-26	SC-01	Administrative	Preventive	Absence of Localized Network SOPs: Lack of documented procedures for communications protection and local network infrastructure management.	Configuration Drift & Stealth Gaps: Local network assets falling out of compliance due to ad-hoc management that is invisible to Corporate IT oversight.	Operational Legal / Regulatory	Integrity Availability	Unmanaged Security Posture: Avoidable vulnerabilities (like unpatched firmware) persist indefinitely because no local staff member is tasked with their oversight or maintenance.	4	3	12	Moderate	Develop and Implement a Local Communications Management SOP.	Mitigate (Remediate)	1. Establish a Maintenance Checklist: Create a monthly local checklist for verifying router firmware versions and rotating administrative credentials (SC-01.a). 2. Define Local Ownership: Formally designate the Center Director as the official responsible for the execution and documentation of local network security tasks (SC-01_ODP[01]). 3. Implement Quarterly Reviews: Establish a 90-day review cycle for local network settings to ensure alignment with the System Security Plan (SC-01_ODP[02]).	1	3	3	Low	Center Director	Open
R-27	SC-07	Technical	Preventive	Absence of Network Segmentation: Use of a "Flat Network" architecture where trusted admin devices and untrusted guest/student devices reside on the same logical subnet.	Lateral Movement & Pivoting: An infected guest device or malicious actor scanning the internal network to exploit the MacBook, Router, or CCTV system.	Operational Legal / Regulatory	Confidentiality Integrity Availability	Center-Wide Compromise: A minor malware infection on a student Chromebook can escalate into a full data breach or network outage by pivoting to high-value administrative targets.	4	4	16	High	Implement Logical Network Segmentation (VLANs).	Mitigate (Remediate)	1. Enforce Technical Isolation: Configure VLANs on the Verizon Gateway and enable "AP Isolation" to prevent peer-to-peer communication between guest and admin devices (SC-07.b). 2. Implement Boundary Firewalls: Define strict access control lists (ACLs) to monitor and restrict traffic flow between subnets, specifically "siloing" the CCTV DVR and Admin MacBook (SC-07.a). 3. Document Security Architecture: Map these managed interfaces in the System Security Plan (PL-02) to ensure they are verified during quarterly configuration audits (SC-07[3]).	1	4	4	Low	Center Director	Open
R-28	SC-21	Technical	Preventive	Insecure DNS Resolution: Lack of DNSSEC validation and reliance on unencrypted DNS requests at the local Verizon Gateway.	DNS Poisoning & MitM Attacks: Malicious actors redirecting local traffic to "spoofed" portals to harvest administrative credentials or deliver malware.	Legal / Regulatory Reputational Operational	Confidentiality	Credential Harvesting & PII Breach: Staff are silently redirected to look-alike domains; stolen credentials allow attackers to access student records at the Corporate level via the compromised local account.	3	5	15	Moderate	Implement Authenticated and Encrypted DNS Resolution.	Mitigate (Remediate)	1. Enable DNSSEC Validation: Configure the Verizon Gateway to use DNSSEC-aware resolvers (e.g., Cloudflare 1.1.1.1) to verify the authenticity of IP addresses (SC-21[1]). 2. Enforce DNS Encryption: Implement DNS over HTTPS (DoH) or TLS (DoT) where hardware supports it to prevent local tampering or "eavesdropping" of web requests (SC-21[2]). 3. Codify Configuration: Document these DNS settings in the Network SOP (SC-01) to ensure they are reinstated after any router factory resets (SC-21_ODP[01]).	1	5	5	Low	Center Director	Open
R-29	SI-02	Technical Administrative	Preventive	Patch Latency & Technical Debt: Reliance on manual updates and the presence of End-of-Life (EOL) legacy hardware that no longer receives security patches.	Automated Exploitation: Botnets and script-kiddies scanning for known CVEs to deploy ransomware or gain remote persistent access.	Operational Legal / Regulatory	Confidentiality Integrity Availability	Perimeter Failure: Vulnerable legacy devices act as an unmitigatable "backdoor," allowing attackers to bypass modern security controls and compromise the entire local network.	5	4	20	Critical	Implement an Automated Patch Management and Lifecycle Policy.	Mitigate (Remediate)	1. Establish a Remediation SLA: Mandate a 30-day window for the installation of all Critical/High security patches across all center hardware (SI-02_ODP[01]). 2. Hardware Decommissioning: Immediately replace EOL legacy devices that have reached "End of Support" and cannot be patched against modern threats (SI-02.c). 3. Enforce Automatic Updates: Configure all manageable endpoints (MacBook, Chromebooks) to download and install security-relevant updates automatically (SI-02.a).	2	4	8	Low	Center Director	Open

Organization: Mathnasium Learning Center (New York) | **Assessment Framework**: NIST SP 800-53 Rev. 5 / FIPS 199 | **Baseline**: Moderate (Student PII) | **Version**: 1.1 (Final) | **Analyst**: K. Oriol / koriol.github.io

Risk ID	Control ID	Control Class	Control Function	Vulnerability	Threat	Business Impact Category	Security Impact Category (CIA)	Consequence	Inherent Likelihood	Inherent Impact	Inherent Risk Score	Inherent Rating	Recommended Action	Risk Treatment Strategy	Mitigation Action Plan	Residual Likelihood	Residual Impact	Residual Risk Score	Residual Rating	Risk Owner	Status
R-30	SI-04	Technical	Preventive Detective	Lack of Centralized Malware Protection: Absence of actively managed anti-malware software on local endpoints (MacBook/iPads).	Malware/Ransomware Infection: Tutors or students inadvertently downloading malicious attachments or visiting compromised sites that execute background code.	Operational Financial Reputational	Integrity Confidentiality	System Hijacking & Data Loss: Malware could encrypt local student files (Ransomware) or exfiltrate administrative passwords, leading to a center-wide operational shutdown.	4	4	16	High	Deploy and Manage Centrally-Monitored Malware Protection.	Mitigate (Remediate)	1. Deploy Antivirus/EDR: Ensure the MacBook Pro and all Windows-based assets have active, real-time malware protection (e.g., Bitdefender or Malwarebytes) installed (SI-03.a). 2. Enable Scheduled Scanning: Configure weekly full-system scans and real-time "on-access" scanning for all files and email attachments (SI-03.c). 3. Automatic Signature Updates: Set the software to check for new malware signatures every 24 hours to ensure protection against the latest threats (SI-03_ODP[01]).	1	4	4	Low	Center Director	Open
R-31	SR-12	Administrative Physical	Preventive	Absence of Hardware Lifecycle Management: Total lack of a formal decommissioning process or "Supply Chain" disposal protocol for retired assets.	Post-Lifecycle Data Recovery: Data scavengers or unauthorized waste processors recovering PII/credentials from devices discarded in standard waste streams.	Legal / Regulatory Reputational	Confidentiality	Supply Chain "Data Spillage": PII is recovered from discarded SSDs or tablets, creating a permanent legal liability for the franchise and violating "Right to Erasure" privacy laws.	4	4	16	High	Establish a Formal Hardware Lifecycle and Disposal SOP.	Mitigate (Remediate)	1. Implement Verification Requirements: Mandate a "Certificate of Destruction" for all hardware sent to external e-waste vendors to ensure a legal chain of custody (SR-12_ODP[01]). 2. Enforce Sanitization Standards: Mandate NIST 800-88 "Purge" or "Destroy" methods for all storage media before they leave the facility (SR-12_ODP[02]). 3. Establish Secure Staging: Create a labeled "Secure Disposal Bin" inside the locked MDF closet to prevent "storage rot" and unauthorized access to legacy devices awaiting disposal (SR-12).	1	4	4	Low	Center Director	Open